Ist eine Datenschutz-Folgenabschätzung nötig?

Eine Prüfliste für die Frage, ob eine Datenschutz-Folgenabschätzung (DSFA) durchzuführen ist. Kreuzen Sie für jede Zeile Ja, Nein oder „?“ (unbekannt) an und notieren Sie, wen Sie gefragt haben.

FÜR WEN
Deutsche Ausgabe. Die italienische Liste (Garante) steht in der englischen Ausgabe: https://finoprivacy.com/documents/dpia-screening.html (auf Englisch). Für nichtöffentliche Verantwortliche in Deutschland (Unternehmen und andere private Stellen), die prüfen, ob eine Verarbeitung eine Datenschutz-Folgenabschätzung (DSFA) erfordert, und für die Fachleute, die sie beraten.

NICHT ABGEDECKT
Die DSFA selbst. Die Listen anderer Länder (Art. 35 Abs. 4 DSGVO). Keine Übereinstimmung mit einer Liste bedeutet nicht, dass keine DSFA nötig ist. Die DSK-Liste gilt nur für den nichtöffentlichen Bereich; Ergänzungen der Länder wurden nicht geprüft.

RECHTSSTAND
DSGVO (Verordnung (EU) 2016/679), deutsche Fassung auf EUR-Lex, gelesen am 8. November 2026; WP 248 Rev. 01 der Artikel-29-Datenschutzgruppe, zuletzt überarbeitet und angenommen am 4. Oktober 2017, deutsche Fassung, gelesen am 8. November 2026; DSK-Liste der Verarbeitungstätigkeiten, für die eine DSFA durchzuführen ist (Muss-Liste), Version 1.1 vom 17. Oktober 2018, gelesen am 8. November 2026

VERSION
1.0, 8. November 2026

Abkürzungen: Art. = Artikel, Abs. = Absatz, Buchst. = Buchstabe, Nr. = Nummer, S. = Seite, Ziffer = nummerierter Absatz der EDSA-Leitlinien.

VERARBEITUNG _____ VERANTWORTLICHER _____

AUSGEFÜLLT VON _____ DATUM _____

Schritt 1. Die drei Fälle, in denen Art. 35 Abs. 3 DSGVO immer eine DSFA verlangt

Kreuzen Sie Ja an, wenn ein Fall zutrifft. Einer genügt.

PUNKT	INHALT	JA	NEIN	?
Art. 35 Abs. 3 Buchst. a DSGVO	Sie bewerten persönliche Aspekte von Personen systematisch und umfassend, automatisiert einschließlich Profiling, und stützen darauf Entscheidungen, die ihnen gegenüber Rechtswirkung entfalten oder sie in ähnlich erheblicher Weise beeinträchtigen.	☐	☐	☐
Art. 35 Abs. 3 Buchst. b DSGVO	Sie verarbeiten besondere Kategorien personenbezogener Daten (Art. 9 Abs. 1) oder Daten über strafrechtliche Verurteilungen und Straftaten (Art. 10) in großem Umfang.	☐	☐	☐
Art. 35 Abs. 3 Buchst. c DSGVO	Sie überwachen öffentlich zugängliche Bereiche systematisch und in großem Umfang (zum Beispiel eine Straße mit Videokameras).	☐	☐	☐

Schritt 2. Die neun Kriterien des WP 248 Rev. 01 (Artikel-29-Datenschutzgruppe, vom EDSA gebilligt)

WP 248 (S. 12 der deutschen Fassung): „Erfüllt ein Verarbeitungsvorgang zwei dieser Kriterien, muss der für die Datenverarbeitung Verantwortliche in den meisten Fällen zu dem Schluss kommen, dass eine DSFA obligatorisch ist". Zählen Sie Ihre Ja-Antworten.

PUNKT	INHALT	JA	NEIN	?
Kriterium 1 WP 248 Rev. 01	Bewerten oder Einstufen, darunter das Erstellen von Profilen und Prognosen (zum Beispiel zu Arbeitsleistung, wirtschaftlicher Lage, Gesundheit, Interessen, Zuverlässigkeit, Verhalten, Aufenthaltsort oder Ortswechsel).	☐	☐	☐
Kriterium 2 WP 248 Rev. 01	Automatisierte Entscheidungsfindung mit Rechtswirkung oder ähnlich bedeutsamer Wirkung für die Personen.	☐	☐	☐
Kriterium 3 WP 248 Rev. 01	Systematische Überwachung von Personen.	☐	☐	☐
Kriterium 4 WP 248 Rev. 01	Vertrauliche oder höchst persönliche Daten.	☐	☐	☐
Kriterium 5 WP 248 Rev. 01	Datenverarbeitung in großem Umfang.	☐	☐	☐
Kriterium 6 WP 248 Rev. 01	Abgleichen oder Zusammenführen von Datensätzen.	☐	☐	☐
Kriterium 7 WP 248 Rev. 01	Daten zu schutzbedürftigen Betroffenen.	☐	☐	☐
Kriterium 8 WP 248 Rev. 01	Innovative Nutzung oder Anwendung neuer technologischer oder organisatorischer Lösungen.	☐	☐	☐
Kriterium 9 WP 248 Rev. 01	Die Verarbeitung selbst hindert Personen daran, ein Recht auszuüben, eine Dienstleistung zu nutzen oder einen Vertrag durchzuführen.	☐	☐	☐

Schritt 3. Die Liste der deutschen Aufsichtsbehörden für den nicht-öffentlichen Bereich (DSK-Muss-Liste, Version 1.1)

Die DSK (Datenschutzkonferenz) ist die Konferenz der unabhängigen Datenschutzbehörden des Bundes und der Länder. Die Nummern 1 und 2 gelten nur zusammen mit mindestens einem von sieben genannten Kriterien aus WP 248. Die Zeilen fassen die Nummern zusammen; prüfen Sie den Originalwortlaut einer Nummer, bevor Sie sich darauf stützen.

PUNKT	INHALT	JA	NEIN	?
Nr. 1 DSK-Muss-Liste	Biometrische Daten zur eindeutigen Identifizierung von Personen, zusammen mit mindestens einem von sieben genannten Kriterien aus WP 248 (vertrauliche Daten und großer Umfang zählen nicht)	☐	☐	☐
Nr. 2 DSK-Muss-Liste	Genetische Daten, zusammen mit mindestens einem von sieben genannten Kriterien aus WP 248 (vertrauliche Daten und großer Umfang zählen nicht)	☐	☐	☐
Nr. 3 DSK-Muss-Liste	Umfangreiche Verarbeitung von Daten, die einem Sozial-, Berufs- oder besonderen Amtsgeheimnis unterliegen	☐	☐	☐
Nr. 4 DSK-Muss-Liste	Umfangreiche Verarbeitung von Daten darüber, wo sich Personen aufhalten	☐	☐	☐

PUNKT	INHALT	JA	NEIN	?
Nr. 5 DSK-Muss-Liste	Zusammenführung von Daten aus verschiedenen Quellen in großem Umfang, für Zwecke, für die nicht alle Daten bei den Personen selbst erhoben wurden, mit für sie nicht nachvollziehbaren Algorithmen, um Grundlagen für Entscheidungen mit Rechtswirkung oder ähnlich erheblicher Wirkung zu schaffen	☐	☐	☐
Nr. 6 DSK-Muss-Liste	Mobile optisch-elektronische Erfassung personenbezogener Daten in öffentlichen Bereichen, die in großem Umfang zentral zusammengeführt werden	☐	☐	☐
Nr. 7 DSK-Muss-Liste	Umfangreiche Erhebung und Veröffentlichung oder Übermittlung von Daten zur Bewertung des Verhaltens und anderer persönlicher Aspekte, die Dritte für Entscheidungen mit Rechtswirkung oder ähnlich erheblicher Wirkung nutzen können	☐	☐	☐
Nr. 8 DSK-Muss-Liste	Umfangreiche Verarbeitung von Daten über das Verhalten von Beschäftigten, die zur Bewertung ihrer Arbeit mit Rechtsfolgen oder anderen erheblichen Folgen genutzt werden können	☐	☐	☐
Nr. 9 DSK-Muss-Liste	Umfassende Profile über Interessen, persönliche Beziehungen oder die Persönlichkeit von Personen	☐	☐	☐
Nr. 10 DSK-Muss-Liste	Zusammenführung von Daten aus verschiedenen Quellen in großem Umfang, für nicht im Voraus bestimmte Zwecke, für die nicht alle Daten bei den Personen selbst erhoben wurden, mit für sie nicht nachvollziehbaren Algorithmen, um bisher unbekannte Zusammenhänge zu entdecken	☐	☐	☐
Nr. 11 DSK-Muss-Liste	Künstliche Intelligenz, die die Interaktion mit Personen steuert oder persönliche Aspekte von ihnen bewertet	☐	☐	☐
Nr. 12 DSK-Muss-Liste	Sensoren oder Funksignale der eigenen Mobilgeräte von Personen, über ihren Bestimmungszweck hinaus genutzt, um über einen erheblichen Zeitraum ihren Aufenthaltsort oder ihre Bewegung zu bestimmen	☐	☐	☐
Nr. 13 DSK-Muss-Liste	Automatisierte Auswertung von Video- oder Audioaufnahmen zur Bewertung der Persönlichkeit	☐	☐	☐
Nr. 14 DSK-Muss-Liste	Umfassende Profile über die Bewegung und das Kaufverhalten von Personen	☐	☐	☐
Nr. 15 DSK-Muss-Liste	Anonymisierung besonderer Kategorien von Daten (Art. 9 DSGVO), nicht nur im Einzelfall, um sie an Dritte zu übermitteln	☐	☐	☐
Nr. 16 DSK-Muss-Liste	Besondere Kategorien von Daten oder Daten über Straftaten, wiederholt durch innovative Nutzung von Sensoren oder mobilen Anwendungen erhoben und von einer zentralen Stelle verarbeitet, auch wenn nicht umfangreich	☐	☐	☐
Nr. 17 DSK-Muss-Liste	Besondere Kategorien von Daten oder Daten über Straftaten, mit denen Anbieter neuer Technologien die Leistungsfähigkeit von Personen bestimmen, auch wenn nicht umfangreich	☐	☐	☐

Bußgeld verhängt, Art. 35 DSGVO unter den Verstößen

Volkswagen: 1,1 Millionen Euro (Landesbeauftragter für den Datenschutz Niedersachsen, 2022). Keine Datenschutz-Folgenabschätzung (Art. 35 DSGVO), neben anderen Verstößen. 2022/DE/050 auf Fino (Seite auf Englisch)

Die Angaben zu den Entscheidungen stammen von enforcementtracker.com (betrieben von CMS) und GDPRhub (noyb) unter CC BY-NC-SA 4.0 (https://creativecommons.org/licenses/by-nc-sa/4.0/) sowie aus den Veröffentlichungen der Behörden selbst; jede Entscheidungsseite auf Fino nennt die Einzelheiten.

Was das Ergebnis bedeutet

Ein Ja in Schritt 1 oder eine Übereinstimmung in Schritt 3: Eine DSFA ist erforderlich (Art. 35 Abs. 3 DSGVO; Listen der Aufsichtsbehörden nach Art. 35 Abs. 4). Zwei oder mehr Ja in Schritt 2: In den meisten Fällen ist eine DSFA erforderlich (WP 248, S. 12 der deutschen Fassung). Nach Art. 35 Abs. 1 DSGVO führt der Verantwortliche die Abschätzung *„vorab“* durch, also bevor die Verarbeitung beginnt.

WP 248 (S. 9 der deutschen Fassung): *„Für den Fall, dass unklar ist, ob eine DSFA erforderlich ist, empfiehlt die WP29-Gruppe dennoch die Durchführung einer DSFA“.*

WP 248 (S. 14 der deutschen Fassung): Erfüllt eine Verarbeitung zwei oder mehr Kriterien aus Schritt 2, hält der Verantwortliche ein hohes Risiko aber nicht für wahrscheinlich, so *„muss der für die Verarbeitung Verantwortliche begründen und dokumentieren, warum er keine DSFA durchführt, und den Standpunkt des Datenschutzbeauftragten mit einbeziehen bzw. festhalten“.*

Die Listen sind nicht abschließend; die DSK schreibt: *„Diese Liste ist nicht abschließend“* (DSK-Muss-Liste, Hinweis 1). Keine Übereinstimmung bedeutet nicht, dass keine DSFA nötig ist. Andere Länder haben eigene Listen (Art. 35 Abs. 4 DSGVO); diese Prüfliste deckt nur Deutschland ab, die englische Ausgabe auch Italien.

Quellen

DSGVO, Verordnung (EU) 2016/679, Art. 35 (EUR-Lex, deutsche Fassung) • Verwendet für: Schritt 1 und die Regel, dass die Abschätzung vor der Verarbeitung erfolgt

WP 248 Rev. 01, Leitlinien zur Datenschutz-Folgenabschätzung (Artikel-29-Datenschutzgruppe, vom EDSA gebilligt); die deutsche Fassung steht in der Datei „Available language versions“ • Verwendet für: Schritt 2, die neun Kriterien, und die zitierten Seiten unter „Was das Ergebnis bedeutet“

WP 248 Rev. 01, alle Sprachfassungen (ZIP-Datei, Europäische Kommission) • Verwendet für: Deutsche Fassung, aus der zitiert wird

DSK, Liste der Verarbeitungstätigkeiten, für die eine DSFA durchzuführen ist (Muss-Liste, nicht-öffentlicher Bereich), Version 1.1 • Verwendet für: Schritt 3, die deutsche Liste